

Marco integrativo GQM + PRAGMATIC para indicadores OWASP 2025 – España

Versión 1.0 – Borrador para pilotos sectoriales y diseño de observatorio nacional

1. Propósito del marco

El presente marco propone integrar dos enfoques complementarios para el diseño y evaluación de indicadores de ciberseguridad basados en OWASP, aplicables al contexto nacional español:

- GQM (Goal–Question–Metric): enfoque orientado a objetivos que parte de metas explícitas, pasa por preguntas de evaluación y termina en métricas cuantitativas alineadas con dichos objetivos.
[web:87][web:95][web:98]
- PRAGMATIC: meta-métrica que evalúa la utilidad de cada indicador según nueve criterios: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno (Timely), Independiente y Rentable (Cheap). [web:88][web:91][web:94][web:96]

Se aplica sobre el catálogo de indicadores OWASP propuestos en el informe previo (M1–M15), orientados a Top 10:2025, SAMM, ASVS 5.0 y la Metodología de Rating de Riesgo, todos ellos con vocación de servir como KPIs/KRIs nacionales alineados con NIS2 y ENS. [web:2][web:21][web:24][web:68][web:97][web:100]

2. Resumen de los indicadores OWASP (M1–M15)

A efectos de este marco, trabajaremos con los siguientes indicadores (resumen conceptual):

- M1 – Densidad de vulnerabilidades OWASP Top 10:2025 en sistemas españoles.
Vulnerabilidades por 100 activos, mapeadas por CWE a categorías Top 10:2025.
- M2 – Proporción de activos críticos sin vulnerabilidades abiertas A01–A03.
% de servicios esenciales/importantes libres de vulnerabilidades altas/críticas de control de acceso, configuración y cadena de suministro.
- M3 – Cobertura de análisis frente a Top 10:2025.
% de aplicaciones/APIs críticas sometidas a pruebas mapeadas explícitamente a Top 10:2025.
- M4 – MTTR de vulnerabilidades Top 10:2025.
Días desde detección hasta cierre en producción para vulnerabilidades altas/críticas.
- M5 – Score medio SAMM por función.
Madurez 0–3 en Gobernanza, Diseño, Implementación, Verificación, Operaciones.[web:68][web:70][web:76]
- M6 – % entidades con nivel ≥ 2 en "Strategy and Metrics" (SAMM).
- M7 – Pendiente anual de mejora SAMM (Δ SAMM).
- M8 – Cobertura de autoevaluaciones SAMM.
% de entidades que se autoevalúan al menos cada 2 años.
- M9 – Distribución de niveles ASVS por criticidad ENS/NIS2.
% de apps críticas en ASVS $\geq$ Nivel 2 (y ≥ 3 según criticidad).
- M10 – Densidad de requisitos ASVS cumplidos por capítulo.
- M11 – Cobertura de pruebas frente a ASVS.
- M12 – Ratio de defectos ASVS en producción.
- M13 – Distribución de severidad OWASP (baja/media/alta) en infraestructuras críticas.
- M14 – Riesgo medio normalizado OWASP por sector.
- M15 – Tiempo medio desde detección técnica a decisión ejecutiva de riesgo.

Estos indicadores se entienden como candidatos a formar parte de un **Índice Global de Madurez (IGM)** con subíndices por exposición, madurez de programa, aseguramiento técnico y gobernanza/cultura.

3. Enfoque GQM aplicado a indicadores nacionales

3.1. GQM en tres niveles

Siguiendo la definición clásica de GQM:[web:87][web:95][web:98]

1. Goal (Meta) – Enunciado del objetivo de medición, asociado a un objeto (programa nacional, sector, organización), con propósito, punto de vista y entorno.
2. Question (Pregunta) – Cuestiones que concretan cómo evaluar el logro de la meta.
3. Metric (Métrica) – Datos cuantitativos que permiten responder a las preguntas.

En el contexto nacional español, las metas se alinean con:

- Objetivos estratégicos nacionales (Estrategia Nacional de Ciberseguridad, Plan Nacional de Ciberseguridad, transposición NIS2).
- Obligaciones ENS/NIS2 (gestión basada en riesgos, medidas técnicas y organizativas, continuidad, gobernanza).[web:21][web:24][web:60][web:72][web:77]

3.2. Ejemplo de plantilla GQM para un indicador

Para cada indicador Mx, se propone estructurar su definición GQM así:

- **Meta Gx**
 Analizar [objeto] con el propósito de [motivo] desde el punto de vista de [rol] en el contexto de [entorno].
- Preguntas Qx.y (2–4 por indicador)
- Qx.1: ...
- Qx.2: ...
- Métricas asociadas (Mx)
 - Definición formal.
 - Unidad de medida.
 - Fuente de datos.
 - Frecuencia.

Meta Gx

Analizar [objeto] con el propósito de [motivo] desde el punto de vista de [rol] en el contexto de [entorno].

Preguntas Qx.y (2–4 por indicador)

Qx.2: ...

Métricas asociadas (Mx)

En la "Matriz de Evaluación PRAGMATIC" se documentan, para cada Mx, los elementos GQM y la puntuación en los nueve criterios.

4. Aplicación GQM resumida por indicador

A continuación se presenta, de forma sintética, el esquema GQM para cada indicador. La versión completa y tabular se desarrolla en la matriz PRAGMATIC.

4.1. M1 – Densidad de vulnerabilidades OWASP Top 10:2025

-

Meta G1

Analizar el ecosistema de sistemas bajo jurisdicción española con el propósito de cuantificar la exposición estructural a las categorías de riesgo OWASP Top 10:2025, desde el punto de vista de autoridades nacionales de ciberseguridad y reguladores, en el contexto de transposición NIS2 y aplicación del ENS.

-

Preguntas clave

- Q1.1: ¿Qué volumen de vulnerabilidades conocidas (CVE) se observa por categoría OWASP Top 10 en los sistemas críticos?
- Q1.2: ¿Cómo varía esa densidad por sector, tamaño de organización y nivel ENS?
- Q1.3: ¿La densidad de vulnerabilidades OWASP tiende a disminuir, mantenerse o aumentar a lo largo del tiempo?

-

Métrica M1

- Definición: vulnerabilidades CVE explotables en sistemas bajo jurisdicción española, mapeadas a CWEs y categorías Top 10:2025, por cada 100 activos inventariados.
- Unidad: vulnerabilidades por 100 activos.
- Fuente: registros de vulnerabilidades de INCIBE-CERT, CCN-CERT y otros CSIRTs sectoriales; inventarios ENS/NIS2.
- Frecuencia: anual, con posibilidad de actualización semestral para series temporales.

Meta G1

Analizar el **ecosistema de sistemas bajo jurisdicción española** con el propósito de **cuantificar la exposición estructural a las categorías de riesgo OWASP Top 10:2025**, desde el punto de vista de **autoridades nacionales de ciberseguridad y reguladores**, en el contexto de **transposición NIS2** y **aplicación del ENS**.

Preguntas clave

Q1.3: ¿La densidad de vulnerabilidades OWASP tiende a disminuir, mantenerse o aumentar a lo largo del tiempo?

Métrica M1

4.2. M2 – % de activos críticos sin vulnerabilidades A01–A03

-

Meta G2

Analizar los activos críticos regulados por ENS/NIS2 con el propósito de evaluar la robustez de controles de acceso, configuración y cadena de suministro (A01–A03), desde el punto de vista de autoridades supervisores y órganos de gobierno corporativos, en el contexto de requisitos mínimos de seguridad y continuidad de servicios esenciales.

-

Preguntas clave

- Q2.1: ¿Qué proporción de activos críticos carece de vulnerabilidades abiertas de alta/crítica severidad en A01–A03?
- Q2.2: ¿Cómo varía este porcentaje por sector y categoría ENS?
- Q2.3: ¿La tendencia es de mejora (más activos “limpios”) o de deterioro?

-

Métrica M2

- Definición: porcentaje de activos críticos sin vulnerabilidades abiertas de severidad alta/crítica asociadas a categorías A01–A03.
- Unidad: %.
- Fuente: bases de datos de vulnerabilidades, herramientas de gestión de parches, inventarios de activos críticos.
- Frecuencia: trimestral o semestral.

Meta G2

Analizar los **activos críticos regulados por ENS/NIS2** con el propósito de **evaluar la robustez de controles de acceso, configuración y cadena de suministro (A01–A03)**, desde el punto de vista de **autoridades supervisores y órganos de gobierno corporativos**, en el contexto de **requisitos mínimos de seguridad y continuidad de servicios esenciales**.

Preguntas clave

Q2.3: ¿La tendencia es de mejora (más activos “limpios”) o de deterioro?

Métrica M2

4.3. M3 – Cobertura de análisis frente a Top 10:2025

-

Meta G3

Analizar las prácticas de prueba de seguridad de aplicaciones/APIs críticas con el propósito de medir la cobertura de detección respecto a las categorías Top 10:2025, desde el punto de vista de CISOs y responsables de pruebas, en el contexto de cumplimiento ENS/NIS2 y programas de mejora OWASP SAMM.

-

Preguntas clave

- Q3.1: ¿Qué porcentaje de aplicaciones críticas se prueba explícitamente frente a las diez categorías Top 10?
- Q3.2: ¿Qué métodos se utilizan (SAST, DAST, SCA, pentesting) y con qué frecuencia?
- Q3.3: ¿Existe correlación entre cobertura de análisis y reducción de incidentes?

-

Métrica M3

- Definición: porcentaje de aplicaciones/APIs críticas sometidas, al menos anualmente, a pruebas con reglas o configuraciones mapeadas al Top 10:2025.
- Unidad: % de aplicaciones.
- Fuente: registros de pruebas, herramientas de CI/CD y ASPM, repositorios de informes de pentesting.
- Frecuencia: anual.

Meta G3

Analizar las **prácticas de prueba de seguridad de aplicaciones/APIs críticas** con el propósito de **medir la cobertura de detección respecto a las categorías Top 10:2025**, desde el punto de vista de **CISOs y responsables de pruebas**, en el contexto de **cumplimiento ENS/NIS2 y programas de mejora OWASP SAMM**.

Preguntas clave

Q3.3: ¿Existe correlación entre cobertura de análisis y reducción de incidentes?

Métrica M3

4.4. M4 – MTTR de vulnerabilidades Top 10:2025

-

Meta G4

Analizar la capacidad operativa de respuesta a vulnerabilidades OWASP con el propósito de medir la agilidad de remediación y compararla con ventanas de explotación típicas, desde el punto de vista de gestores de riesgo y operaciones, en el contexto de objetivos de resiliencia y continuidad de negocio.

-

Preguntas clave

- Q4.1: ¿Cuántos días pasan, de media, entre la detección y el cierre de vulnerabilidades altas/críticas Top 10 en activos críticos?
- Q4.2: ¿Cómo se compara este tiempo con recomendaciones, SLAs internos y ventanas de explotación observadas?
- Q4.3: ¿Hay diferencias significativas entre sectores o tipos de organización?

-

Métrica M4

- Definición: tiempo medio (en días) desde la detección hasta el cierre de vulnerabilidades de severidad alta/crítica asociadas al Top 10:2025 en activos críticos.
- Unidad: días.
- Fuente: sistemas de ticketing, gestores de vulnerabilidades, registros de cambios.
- Frecuencia: trimestral.

Meta G4

Analizar la **capacidad operativa de respuesta a vulnerabilidades OWASP** con el propósito de **medir la agilidad de remediación y compararla con ventanas de explotación típicas**, desde el punto de vista de **gestores de riesgo y operaciones**, en el contexto de **objetivos de resiliencia y continuidad de negocio**.

Preguntas clave

Q4.3: ¿Hay diferencias significativas entre sectores o tipos de organización?

Métrica M4

(La matriz PRAGMATIC detalla de igual forma las metas y preguntas para M5–M15: SAMM, ASVS, riesgo agregado y gobernanza.)

5. Criterios PRAGMATIC

Tomando la definición de Brothby e Hinson, PRAGMATIC es un acrónimo que resume nueve criterios para evaluar la calidad de una métrica:[web:88][web:91][web:94][web:96]

4. Predictive (Predictivo) – ¿Hasta qué punto ayuda la métrica a anticipar eventos futuros (incidentes, fallos, incumplimientos)?
5. Relevant (Relevante) – ¿Está directamente vinculada con objetivos y riesgos importantes para la organización o el país?
6. Actionable (Accionable) – ¿Sugiere acciones claras que se pueden emprender para mejorar la situación?
7. Genuine (Genuino) – ¿Refleja la realidad y no se ve fácilmente manipulada o maquillada?
8. Meaningful (Significativo) – ¿Es comprensible para sus destinatarios y aporta contexto, no solo números?
9. Accurate (Preciso) – ¿Es lo suficientemente precisa para soportar decisiones (sin ruido o errores excesivos)?
10. Timely (Oportuno) – ¿Está disponible con la frecuencia y rapidez necesarias para influir en decisiones?
11. Independent (Independiente) – ¿Depende lo menos posible de fuentes sesgadas o conflictivas? ¿Es verificable?
12. Cheap (Rentable) – ¿El coste de obtener y mantener la métrica es razonable frente al valor que aporta?

Cada indicador Mx se puntúa en una escala, por ejemplo de 0 a 5, donde:

- 0 = Muy pobre / no cumple.
- 1-2 = Débil.
- 3 = Aceptable.
- 4 = Bueno.
- 5 = Excelente.

La "Matriz de Evaluación PRAGMATIC Completa" contiene las puntuaciones y justificaciones para cada Mx.

6. Integración QQM + PRAGMATIC en el ciclo de vida de los indicadores

6.1. Fases

13. Definición (GQM)
14. Identificar metas nacionales/sectoriales (NIS2, ENS, estrategias nacionales).[web:21][web:24][web:60][web:72][web:77]
15. Derivar preguntas de evaluación.
16. Seleccionar/definir métricas candidatas (M1–M15).
17. Evaluación (PRAGMATIC)
18. Puntuar cada métrica según los nueve criterios.
19. Documentar fortalezas, debilidades y riesgos de uso.
20. Seleccionar un subconjunto “estrella” para dashboards de alto nivel.
21. Implantación
22. Integrar métricas en procesos y herramientas (inventarios, gestores de vulnerabilidades, SAMM, ASVS, etc.).[web:2][web:68][web:97][web:100]
23. Asegurar responsabilidades claras de recogida y revisión.
24. Revisión y mejora
25. Revisar periódicamente metas, preguntas y métricas a la luz de datos empíricos.
26. Recalibrar ponderaciones (por ejemplo, en el IGM) y descartar métricas que puntúen mal en PRAGMATIC sin justificación.

Seleccionar/definir métricas candidatas (M1–M15).

Evaluación (PRAGMATIC)

Seleccionar un subconjunto “estrella” para dashboards de alto nivel.

Implantación

Asegurar responsabilidades claras de recogida y revisión.

Revisión y mejora

6.2. Ejemplo de decisiones basadas en PRAGMATIC

- Si una métrica es muy precisa pero poco accionable, conviene complementarla con otra que señale mejor el “qué hacer”.
- Si una métrica es muy predictiva pero poco genuina (fácil de maquillar), habrá que reforzar controles de calidad o buscar alternativas.
- Si una métrica es muy relevante pero nada rentable de medir a escala nacional, quizá deba reservarse para estudios puntuales o muestras.[^]

7. Alineamiento con OWASP, NIS2 y ENS

Este marco integrativo se apoya en:

- La orientación a metas y madurez de OWASP SAMM (especialmente la práctica "Strategy and Metrics").[web:68][web:70][web:100]
- El énfasis de OWASP Security Culture en métricas que cuenten una historia útil y permitan justificar acciones y recursos.[web:2][web:97]
- La necesidad, recogida en NIS2 y ENS, de que las medidas de seguridad sean proporcionadas al riesgo, lo que exige métricas robustas y alineadas con objetivos reales.[web:21][web:24][web:60][web:72][web:77]

GQM garantiza que cada indicador OWASP tenga sentido en el contexto de los objetivos nacionales; PRAGMATIC ayuda a decidir qué indicadores merecen realmente un lugar en el cuadro de mando.

Este documento sirve como marco conceptual; las plantillas, matrices y guías operativas asociadas completan el "kit" para llevarlo a la práctica.